

12-Security-Governance-Compliance.md

Healthcare Clinical Intelligence Platform

Enterprise Security, Governance & Compliance Architecture

Version: 1.0

Status: Approved Design

Mission

Build a healthcare-grade AI platform that is:

- Secure by Design
- Governed by Policy
- Auditable by Default
- Compliance Ready
- Zero Trust Oriented

The platform must assume:

Users make mistakes.

Agents make mistakes.

Models hallucinate.

Attackers exist.

The architecture must protect against all of them.

Security Principles

Principle 1

Least Privilege Access

Principle 2

Default Deny

Principle 3

Zero Trust

Principle 4

Audit Everything

Principle 5

Human Oversight For High Risk Actions

Compliance Targets

Architecture designed to support:

- HIPAA
 - GDPR
 - SOC2
 - ISO 27001
 - HITRUST (Future)
-

Data Classification

Public

Marketing Material

Public Research

Internal

Internal SOPs

Internal Documentation

Confidential

Patient Education

Insurance Data

Operational Data

Restricted

PHI

PII

Medical Records

Clinical Data

Tenant Isolation

Every request must include:

`organization_id`

Mandatory.

Query Enforcement

Every retrieval filtered by:

```
organization_id
department_id
role
knowledge_base_id
```

Authentication Architecture

Provider:

Supabase Auth

Supported Methods

Email + Password

Magic Link

SSO (Future)

SAML (Future)

OIDC (Future)

MFA (Future)

Authorization Architecture

RBAC

Roles

Platform Super Admin

Organization Admin

Department Admin

Doctor

Pharmacist

Researcher

Viewer

Permission Model

```
graph TD;
  Role --> Permissions;
  Permissions --> Resources;
```

Example

Doctor

Can:

Read Documents

Query AI

View Citations

Cannot:

Approve Documents

Manage Users

Data Encryption

At Rest

AES-256

In Transit

TLS 1.3

Secrets Management

Never store secrets in code.

Use

AWS Secrets Manager

Stores

API Keys

Database Credentials

JWT Secrets

Third Party Tokens

Encryption Keys

PII Protection

Detect:

Names

Addresses

Emails

Phone Numbers

Patient Identifiers

Medical Record Numbers

PII Pipeline

```
graph TD; Input --> PII_Detector[PII Detector]; PII_Detector --> Masking; Masking --> Storage;
```

Input
↓
PII Detector
↓
Masking
↓
Storage

PHI Protection

Protected Health Information must:

- Be encrypted
 - Be access controlled
 - Be audited
-

Data Retention Policy

Conversations

Configurable

Audit Logs

7 Years

Documents

Organization Controlled

Evaluations

Long-Term Storage

Audit Architecture

Every action logged.

User Actions

Login

Logout

Query

Upload

Approval

Delete

Export

Agent Actions

Retrieval

Validation

Memory Creation

Safety Decision

Audit Event Structure

```
{  
  "event_id": "",  
  "user_id": "",  
  "organization_id": "",  
  "action": "",  
  "resource": "",  
  "timestamp": ""  
}
```

Document Governance

States

Draft

Pending Review

Approved

Archived

Retrieval Rule

Only Approved documents searchable.

Version Governance

Never overwrite.

All versions retained.

Approval Governance

Required For

Document Approval

Memory Promotion

Policy Changes

Knowledge Base Publication

Agent Governance

Agents cannot:

Approve Documents

Modify Policies

Change Permissions

Promote Memories

Delete Records

Human In The Loop

Required For

High-Risk Updates

Policy Changes

Memory Promotion

Document Publication

Memory Governance

Agent Memory



Review Queue



Human Approval



Production Memory

AI Governance

All AI outputs must:

Include Citations

Include Confidence

Include Source Information

AI Restrictions

The system must not:

Invent Sources

Invent Citations

Provide Unsupported Medical Advice

Bypass Safety Rules

Healthcare Safety Policy

If evidence weak:

Insufficient evidence available.

Instead of hallucinating.

Security Monitoring

Track:

Failed Logins

RBAC Violations

Unauthorized Access

Suspicious Activity

API Abuse

Rate Limiting

Per User

Per API Key

Per Organization

API Security

API Keys

JWT Validation

Request Logging

Rate Limiting

Tenant Validation

Data Export Controls

Exports require:

Authorization

Audit Log

Ownership Validation

Backup Security

Encrypted Backups

Versioned Backups

Geo-Redundant Storage

Incident Response

Detection

↓

Investigation

↓

Containment

↓

Recovery

↓

Postmortem

Disaster Recovery

Targets

RPO < 1 Hour

RTO < 4 Hours

Compliance Dashboard

Displays

Audit Coverage

Policy Violations

Security Events

Access Reports

Approval Activity

Governance Dashboard

Displays

Document Status

Memory Status

Pending Reviews

Policy Changes

Approval Queues

Security KPIs

100% Audit Coverage

0 Cross-Tenant Data Leaks

0 Unauthorized Access Events

99.9% Authentication Success

Governance KPIs

100% Approved Documents

100% Version Tracking

100% Memory Review Coverage

100% Citation Coverage

Future Enhancements

ABAC (Attribute Based Access Control)

Data Residency Controls

Fine-Grained Document Permissions

Advanced Consent Management

HIPAA Certification Path

Final Principle

Security is not a feature.

Governance is not a feature.

Compliance is not a feature.

They are foundational requirements for trust in healthcare AI systems.